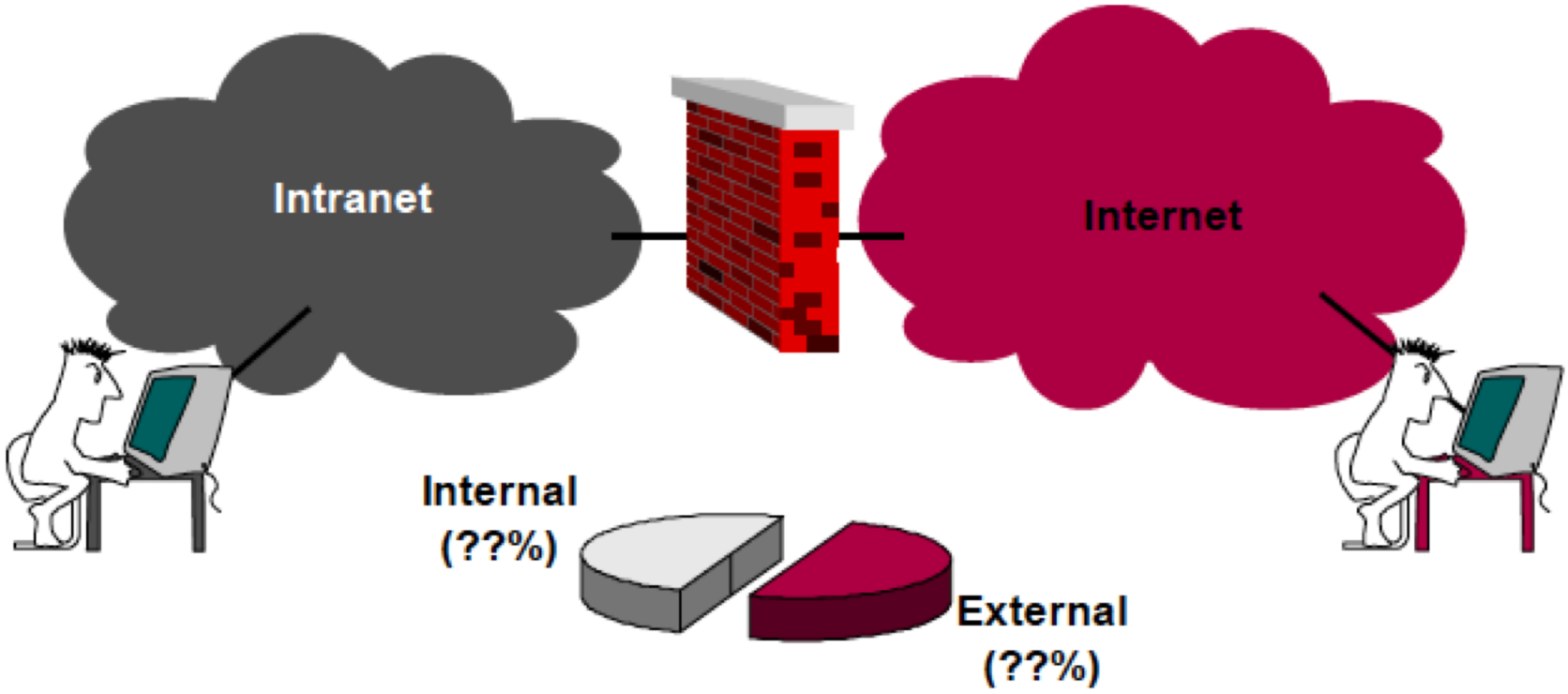
Security
Hacking and Protection

Source : HASHCAT (https://hashcat.net/hashcat/), Master course at the university of Berkely, Tutorial on password hacking (Youtube)

Introduction

- Les systèmes informatique en réseau sont de plus en plus complexes
- Difficile de vérifier qu'un système fait bien ce qu'on lui demande, impossible de vérifier qu'il ne fait pas ce qu'on ne lui demande pas
- Le but de la sécurité
  - La confidentialité,
  - L'intégrité et
  - La disponibilité des données

D'où proviennent les attaques?



- Les statistiques sont très variées
- Les attaques ne proviennent pas seulement de l'extérieur

Problématique de la détection d'intrusion

- De nouvelles attaques exploitent les vulnérabilités des systèmes et des réseaux
  - Attaques contre la disponibilité, mais aussi contre la confidentialité et l'intégrité
  - Attaques externes et attaques internes

- De plus en plus, utilisation d'attaques coordonnées
  - Exemple 1 : attaque contre les sites de plusieurs serveurs américains en Février 2000
    - Corruption de plusieurs sites relais
    - Puis attaques coordonnées par ces sites relais (Smurfing)
  - Exemple 2 : Mitnick attack

Un peu d'histoire



- Kevin Mitnick
  - Le plus médiatisé des pirates:
    3 livres, un film
  - Il a commencé par pirater des réseaux téléphoniques
  - A attaqué les machines de Tsumotu Shimomura au San Diego Supercomputing center
  - S'en suit un traque entre le bon et le méchant pirate (white hat vs black hat)

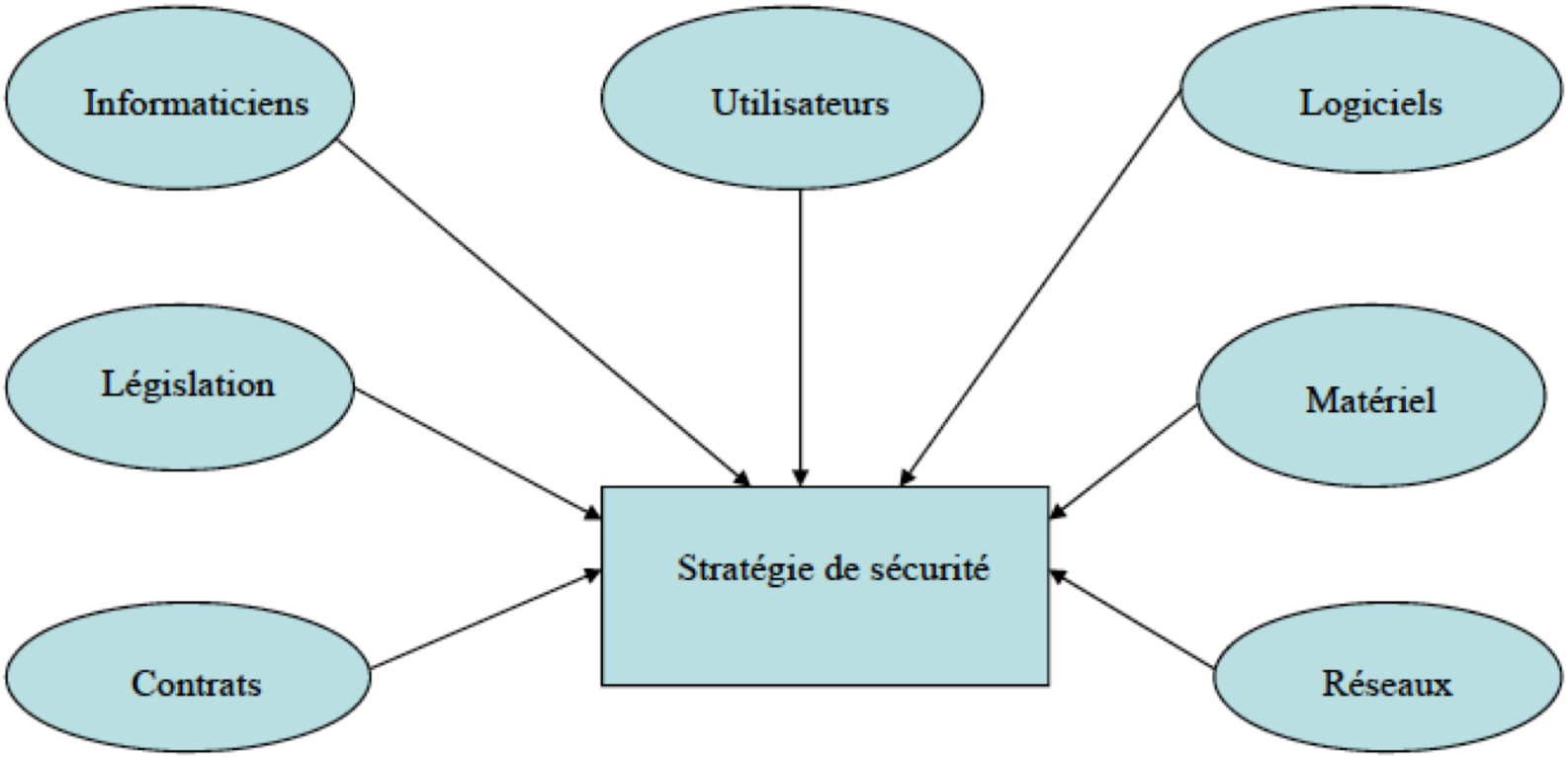
Hameçonnage (*phishing)*

- L'**hameçonnage**, ***phishing*** ou **filoutage** est une technique utilisée par des fraudeurs pour obtenir des renseignements personnels dans le but de perpétrer une usurpation d'identité.
- La technique consiste à faire croire à la victime qu'elle s'adresse à un tiers de confiance: banque, administration, etc.
  - Exemple: Ebay et Paypal

Chevaux de troie

- Très répandu (exemples: attaque du ministère de l'économie et des finances rendu public en décembre 2010, attaque contre AREVA rendu public le 29 septembre 2011, infections par des vulnérabilités d'Internet Explorer en septembre 2012, …)
- Quelques exemples anciens de chevaux de Troie:
  - Back Orifice: Permet de l'« administration à distance».
- Le cheval de Troie prend l'apparence d'un logiciel existant, légitime et parfois même réputé, mais qui aura été modifié pour y dissimuler un parasite.

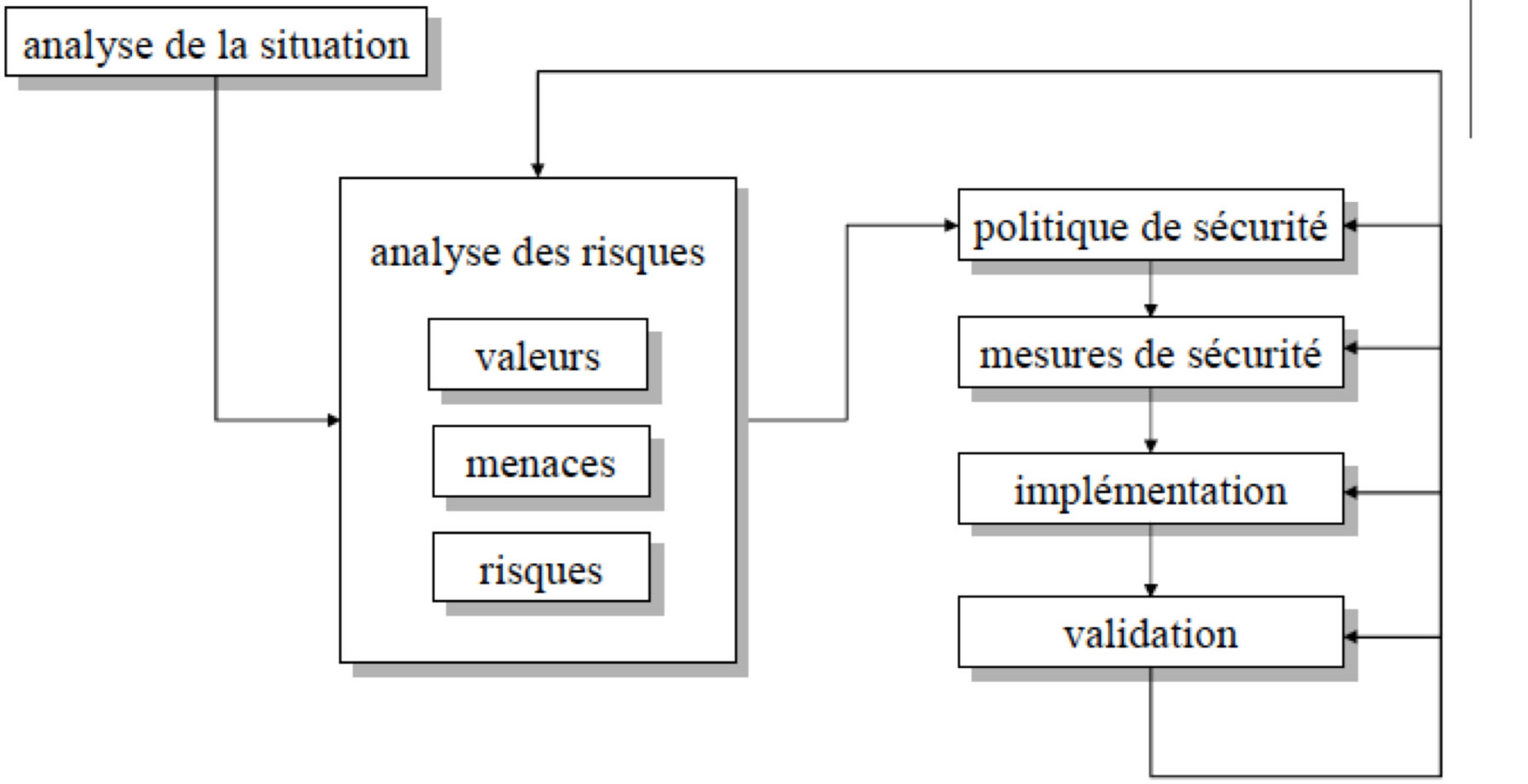
La sécurité : une nécessité



Niveaux de sécurisation

- Sensibilisation des utilisateurs aux problèmes de sécurité.
- Sécurisation des données, des applications, des systèmes d'exploitation.
- Sécurisation des télécommunications.
- Sécurisation physiques du matériel et des accès.

Une approche systématique



Authentication

- Passwords are cheap to deploy, but also act as the first line of defense in a security arsenal.
  - They are also often the weakest link.
- Examples of what they protect:
  - ATMs and bank accounts
  - Nuclear power and other critical infrastructure systems
  - Company proprietary information and systems
  - Email accounts (Gmail, Hotmail, Yahoo, AOL, etc.)
  - Student information (e.g. ENT & WebCT)

Authentication

- Passwords = secret authentication code used for access.
- Answers the question: How do you prove to someone that you are who you claim to be?
- Authentication methods:
  - What you know (Passwords, Secret keys, Personal Information)
  - Where you are (IP Addresses)
  - What you are (Biometrics)
  - What you have (Secure tokens)

Passwords

AAA of Password Security

- Authentication (& Identification)
  - Establishes that the user is who they say they are (credentials).
- Authorization
  - The process used to decide if the authenticated person is allowed to access specific information or functions.
- Access Control
  - Restriction of access (includes authentication & authorization)

Passwords

How Can Passwords Be Stored?



- Filing System
  Clear text

- Dedicated Authentication Server
  Clear text

Encrypted
Password + Encryption = bf4ee8HjaQkbw

Hashed
Password + Hash function = aad3b435b51404eeaad3b435b51404ee

Salted Hash
(Username + Salt + Password) + Hash function =
e3ed2cb1f5e0162199be16b12419c012

Passwords

UNIX Systems

- In past UNIX systems, password used modified DES (encryption algorithm) as if it were a hash function
  - Encrypts NULL string using password as the key (truncates passwords to 8 characters!)
  - Caused artificial slowdown: ran DES 25 times
- Also stored password file in directory: /etc/passwd/
  - World-readable (anyone who accessed the machine would be able to copy the password file to crack at their leisure)
  - Contained userIDs/groupIDs used by many system programs
  - Can instruct modern UNIXes to use MD5 hash function

Passwords

Windows

- Uses 2 functions for "hashing" passwords:
  1. LAN Manager hash (LM hash)
     - Password is padded with zeros until there are 14 characters.
     - It is then converted to uppercase and split into two 7-character pieces
     - Each half is encrypted using an 8-byte DES (data encryption standard) key
     - Result is combined into a 16-byte, one way hash value
  2. NT hash (NT hash)
     - Converts password to Unicode and uses MD4 hash algorithm to obtain a 16-byte value
- Hashes stored in Security Accounts Manager (SAM)
  - Locked within system kernel when system is running.
  - Location - C:\WINNT\SYSTEM32\CONFIG
- SYSKEY
  - Utility which moves the encryption key for the SAM database off of the computer

L0phtCrack

- **L0phtCrack** is a password auditing and recovery application
- It is used to test your password
- It attempts to crack passwords from hashes
- How it works?



Passwords

Why Cracking is Possible

- Passwords are NOT truly random
  - 52 upper/lowercase letters, 10 digits, and 32 punctuation symbols equals ≈ 6 quadrillion possible 8-character passwords
  - People like to use dictionary words, relative and pet names equaling ≈ 1 million common passwords
  - On average, each person has 8-12 passwords:
  - Different systems impose different password requirements.
  - Passwords need to be changed often.
  - Some passwords are only used occasionally.

Password Cracking methods

- Attacker can compute H(word) for every word in a dictionary and see if the result is in the password file
- With 1,000,000-word dictionary and assuming 10 tests per second, brute-force online attack takes 50,000 seconds (14 hours) on average
  - Offline attack is much faster!

Password Cracking methods

- Dictionary Attack
  - Quick technique that tries every word in a specific dictionary
- Hybrid Attack
  - Adds numbers or symbols to the end of a word
- Brute Force Attack
  - Tries all combinations of letters, numbers & symbols
- Popular programs for password cracking
  - LophtCrack (discontinued by Symantec when acquired @stake
  - RainbowCrack : It supports HTTP (Basic Authentication), HTTP (HTML Form/CGI), POP3, FTP, SMB, Telnet and other types such as IMAP and NNTP.
  - Brutus (online cracking)
  - Wfuzz : Web application password cracking tool
  - Cain and Abel **:** It can work as sniffer in the network, cracking encrypted passwords using the dictionary attack

Passwords

Improving Security

- Password complexity
  - Case-sensitivity
  - Use of special characters, numbers, and both upper and lower-case letters
  - Minimum length requirements
- Security questions
  - Ask personal questions which need to be verified
  - Some questions are very easy to discover answers
- Virtual keyboard
  - Person clicks on-screen keyboard to enter password (prevents keylogging)

- Single sign-on
  - User only has to remember one password at a time and yet can access all/most of their resources
  - AKA Enterprise Reduced Sign-On (almost impossible to have one password used for everything due to integration issues)
- Centralized password storage management
  - Online sites accessible through one password which contain all other passwords

Single point of failure, but easier to remember

Passwords

Ten Common Mistakes

1. Leaving passwords blank or unchanged from default value.
2. Using the letters p-a-s-s-w-o-r-d as the password.
3. Using a favorite movie star name as the password.
4. Using a spouse's name as the password.
5. Using the same password for everything.
6. Writing passwords on post-it notes.
7. Pasting a list of passwords under the keyboard.
8. Storing all passwords in an Excel spreadsheet on a PDA or inserting passwords into a rolodex.
9. Writing all passwords in a personal diary/notebook.
10. Giving the password to someone who claims to be the system administrator.

Password Cracking

- There are several methods for password cracking available.
  - Brute-force cracking, in which a computer tries every possible key or password until it succeeds.
  - Dictionary attacks, pattern checking, word list substitution, etc., attempt to reduce the number of trials required and will usually be attempted before brute force.



HASHCAT

- Hashcat claims to be the world's fastest CPU and GPU password
- HASHCAT supports a large variety of hashing algorithm, including LM HASH, MD4, MD5, SHA-1 and -2, UNIX Crypto formats..
- Open-source (MIT License)
- It can be used to crack WPA2 (WiFi)

Big risk with HASHCAT

- Passwords that were once considered secure are no longer so
- Passwords that are hashed with out being salted are almost a joke
- Anything under 12 characters is easily broken

HASHCAT Attacks

- Dictionary attack - trying all words in a list; also called “straight” mode (attack mode 0, -a 0)
- Combinator attack - concatenating words from multiple wordlists (mode 1)
- Brute-force attack and Mask attack - trying all characters from given charsets, per position (mode 3)
- Hybrid attack - combining wordlists+masks (mode 6) and masks+wordlists (mode 7)

Application : Innovation

- How Artificial Intelligence can be used for password guessing?
- How to generate high-quality password guesses?
- Several datasets will be tested such as RockYou dataset leaked passwords from LinkedIn.
- Compare the proposed solution with HASHCAT tool.